

Linux CVEs

Context

- Since Feb '24, Linux is its own CNA
- [Linux Kernel CVEs, What Has Caused So Many to Suddenly Show Up? - Greg Kroah-Hartman @ CNCF](#)
- CVE volume has significantly increased
 - Before: ~20/month
 - After: ~60/**week**
 - 1300+ filed from past commits

Challenge

- How do we triage them all?
- Different challenges for different players in the community
- For a cloud provider:
 - Can't reboot machines
 - Decision in {ignore, (expedite) backport, livepatch}
- Applicability depends on threat model, exploitability, permissions, etc.
- Is there space for collaboration?

Idea 0 - Open collaboration

- [linux-cve-announce](#) currently only has CVE assignments and is private
- Encourage CVE consumers to share their analysis
- Can be done in incremental steps:
 - X says CVE is only reachable locally, analysis done for X
 - Y actually cares about local bugs, but says code requires CAP_NET_ADMIN, analysis done for Y
- Can boost discussion
 - Z may observe that code is network-reachable in some cases
- Ultimately aim for some parsable labels/tags

Idea 1 – Cloud LTS tree

- Assumption: shared threat model and constraints in hyperscaling env
- Maintain a separate tree, based on a LTS release
- Only backport selected security issues
 - High impact
 - Livepatchable
 - Add trailers/additional files with annotations
- Community-driven
 - Trade-off: config-based filtering vs # of contributors
 - Main challenge is again choosing which commits to backport

Idea 2 – Boost plumbers' involvement

- Bar for rejection vs bar for acceptance
- Give them a chance to reject a CVE before it's assigned?
 - Ask them as soon as the patch is reviewed, using some bot?
 - If CVE assignment is already script-aided, such a script could be run earlier
 - Requires documentation on which assumptions are *reasonable*
- Obviously, opt-in only